

Policy_ID: CIP-ICF-006

**Policy_Name: Industry-Specific Regulatory
Compliance Framework**

Version: 2.1

Effective_Date: 2025-12-05

Risk_Category: Legal & Compliance

**Applicable_Regulations: [FFIEC, PCI-DSS, HIPAA,
NERC-CIP, SOX, GDPR]**

Owner: Regulatory Affairs & Legal Risk Management

Industry-Specific Regulatory Compliance Framework

1. Purpose & Scope [Risk Score: 1]

This framework establishes governance for Capstone operations in regulated sectors (Financial Services, Healthcare, Critical Infrastructure). It applies to all systems, data, and workflows delivering regulated services.

2. Regulatory Landscape [Risk Score: 4]

Capstone operates under stringent regulatory obligations. Business leaders must map relevant obligations:

- **Financial:** FFIEC, PCI-DSS, GLBA, RBI (India).
- **Healthcare:** HIPAA, HITECH, EU MDR.
- **Infrastructure:** NERC-CIP, NIST Critical Infrastructure.

Non-Compliance Impact: Failure to identify and apply the correct regulatory framework is a **High Risk** violation potentially rendering business operations illegal in specific jurisdictions.

3. Mandatory Compliance Controls [Risk Score: 5]

The following baseline controls are mandatory for all regulated operations:

- **Segregation of Duties (SoD):** Mandatory for financial and risk-sensitive roles.
- **Control Testing:** Quarterly or semi-annual cycles required.

- **Evidence Retention:** Must meet industry-specific periods (e.g., 7-10 years for Finance).

Non-Compliance Impact: Missing a mandatory control test or failing SoD is a **Critical Risk** (Score 5) that can lead to audit failure and loss of operating licenses.

4. Technical Controls [Risk Score: 5]

Core technical requirements for regulated systems include:

- **Encryption:** Minimum **AES-256** for data at rest; **TLS 1.2+** for transit.
- **Authentication: Multi-Factor Authentication (MFA)** is mandatory for all regulated systems.
- **Monitoring:** SIEM monitoring and alerting for all high-risk activities.

Non-Compliance Impact: Deploying a regulated system without MFA or Encryption is a **Critical Risk** violation.

5. Financial Compliance [Risk Score: 5]

For FinTech and financial service operations:

- **AML/KYC:** Mandatory screening and documentation.
- **Reporting:** Accurate financial reporting and suspicious activity reporting (SAR).
- **Integrity:** Integrity of risk scoring engines must be verified annually.

Non-Compliance Impact: Failure to report suspicious financial activity is a **Critical Risk** carrying potential criminal liability for the firm and individuals.

6. Third-Party Oversight [Risk Score: 4]

- **Due Diligence:** Mandatory compliance certification checks for vendors.
- **Audits:** Periodic third-party audits required.
- **Termination:** Immediate suspension of vendors for repeated non-compliance.

Non-Compliance Impact: Engaging a non-compliant vendor for regulated services is a **High Risk** supply chain violation.

7. Breach Handling [Risk Score: 5]

- **Root Cause Analysis:** Must be completed within **72 hours**.
- **Notification:** Reporting to regulators where legally required.
- **Isolation:** Immediate isolation of impacted systems.

Non-Compliance Impact: Late reporting of a breach to regulators (e.g., beyond 72 hours) is a **Critical Risk** resulting in maximum statutory fines.